HIPAA Self Assessment
Introduction and Explanations

This self assessment is designed to provide covered entities with an idea of how they might fare in a HIPAA audit. It contains 78 questions to which you will be asked to answer “yes,” “no,” “uncertain” or “non-applicable.” Questions in this self-assessment are phrased so that "correct" answers are "yes" or “non-applicable”. HIPAA has both Privacy rules and Security rules. This self-assessment is also split into those two sets of rules. There is no "grade" for this self-assessment, nor is there a "poor", "fair", "good" rating scale. There is no prescribed number of "No" answers that indicate an entity is in trouble. It is important to remember that HIPAA compliance is evaluated using what is known as "compliance testing". In compliance testing, partial credit is not given for an item. An entity is either in compliance or not in compliance with a particular item. Obviously, some requirements carry more risk or more weight, but the bottom line is that if all conditions of a requirement are not

If can answer "Yes" to all 78 questions, you are probably doing a good job of protecting your information and you may well be in compliance with HIPAA regulations.

On the other hand, if you responded to any questions with a "No" answer, your data security and/or privacy standards are probably not adequate. The more "No" answers you selected, the more likely it is that you are even further away from compliance with HIPAA regulations.

How to complete the assessment.

The best way to use this tool is to act as if an auditor is asking the questions of you. Auditors always expect evidence that you are completely answering the question. As a result, during a real audit, you will be required to provide evidence to support your answers. While for your self-assessment, you do not necessarily need to **gather** the evidence, you should spend some time clearly visualizing how the information should be obtained. For example, rather than simply answering yes to a question of whether you have developed a particular policy, enter the web site where the policy can be found into the comments section.

If a question is asking whether you train employees, think of how you can prove that - for example, by providing completed quizzes, or signed attendance records. If an auditor can't verify the training took place with objective proof, it didn't happen. You don't have to collect all evidence for the self-assessment, but to answer "Yes" to this question, you should be able to explain how to obtain the evidence.

The answers!

Yes - this answer is not the end of the tale. Any "Yes" answer must be backed up by solid evidence. Auditors will expect verification of any "Yes" answer.

No - Even "No" answers can use explanations. For example, if a training program is not yet in place, but is 90% developed and will be launched soon, it is appropriate to put this fact in the assessment.
Uncertain - answers obviously indicate that there is more work to do. HIPAA auditors will expect firm answers to

N/A - If a question is not applicable to your covered entity, provide some justification or evidence to that effect.

Please note that if an item refers to existing campus policy, the covered unit is still responsible for knowing the policy, making sure they are fully addressing the issue, and providing evidence of compliance.

Click on the "Privacy Section" button at the bottom of the screen to continue.

HIPAA Self-Assessment
PRIVACY SECTION

Entity: _____

Date: _____

Compiled By: _____

For each item, please provide comments if appropriate, including:

- brief descriptions of implemented practice
- plans and timelines for any "No" answers

Please submit to:

Internal Audit

Item	Specific Requirement	Yes/ No/ Uncertain	Section of Manual	Subsection	Comments
1	We are able to identify health information as "protected health information".		A		
2	We utilize the training program for all employees and volunteers who use Protected Health Information (PHI). We regularly verify and retain evidence that all employees using PHI meet the training requirements.		C		
3	We have named a privacy officer for our unit, and the privacy officer is cognizant of the authority and responsibility inherent in the role.		C		
4	Our privacy officer has formally acknowledged the responsibilities as set forth in the UWM HIPAA Polices and Procedures document.		C		
5	We have identified an individual responsible for acting as a liaison with the Security Officer and ensuring on a unit level that we comply with HIPAA security regulations.		D		
6	We have an inventory of PHI and EPHI information.		E		
7	We have mechanisms in place for using and disclosing only the minimum amount of PHI necessary to accomplish the purpose of the use or disclosure.		E		
8	We have physical control of the areas that house PHI, and have written policies and procedures describing that access control.		E		
9	Computer monitors that can access PHI are placed so that they cannot be seen from any position other than the primary user.		E		
10	Screen savers are automatically engaged when workstations are not in active use, and are password protected.		E		
11	Paper records are shredded, and any unshredded materials scheduled for destruction are kept in locked containers.		E		
12	Fax machines are located in restricted areas, and faxes are never left on the machine unattended.		E		
13	Sign-in logs only contain minimal PHI such as a patient's name and do not contain patient condition.		E		
14	We are aware of the policies regarding emergencies, and have developed procedures for tracking responses in emergency circumstances.		E, F, L		
15	We utilize a Notice of Privacy Practices (NPP). If we have a custom NPP, we have consulted with and notified Legal Affairs.		F		
16	We have our current Privacy Officer and contact information on the NPP				
17	If we have a website, the NPP is posted on the website.		F		
18	We give patients the opportunity to object before disclosing PHI to those involved in patient care.		G		
19	We follow policy regarding facility patient directories, and retain evidence that patients have been given an opportunity to object to such disclosure.		I		
20	We use the UWM Authorization Form for disclosure of PHI, and it is updated with current Departmental name and contact information. If we have developed our own form, it has been approved by Legal Affairs.		H		
21	We use the UWM Authorization Form for disclosure of Psychotherapy Notes, and it is updated with current Departmental name and contact information. If we have developed our own form, it has been approved by Legal Affairs.		H		
22	We have a process for patients to revoke authorization for disclosure of PHI or Psychotherapy Notes		H		
23	We have determined if and how we will create de-identified health information, pursuant to the policy. We have identified the circumstances and process used to decide on release of de-identified information. This process also includes adherence to other applicable regulations such as FERPA and GLBA.		I		
24	We have determined if and how we will allow disclosure of limited data sets. If we allow disclosure of limited data sets, we enter into a Data Use Agreement with the recipient, and follow the policy as to Limited Data Sets.		J		
25	We maintain an accounting of disclosures of PHI requests pursuant to policy.		K		
26	Unauthorized disclosures are logged and reviewed. Unauthorized disclosures are immediately disclosed to Legal Affairs. If unauthorized disclosures involve electronic records, the Security Officer (see section D) is informed.		K		

Item	Specific Requirement	Yes/ No/ Uncertain	Section of Manual	Subsection	Comments
27	We follow policy to allow patients to request that their health information not be used or disclosed for treatment, payment, or healthcare operations (such requests may be denied).				
28	We follow policy to allow patients to request receipt of communications of PHI by alternate means or at an alternative location.				
29	We follow policy to allow patients to access, photocopy, and inspect PHI upon request.		L		
30	We follow policy to allow patients to request amendment or correction of PHI that is inaccurate or incomplete.		L		
31	We follow policy to allow patients to request an accounting of disclosures.		L		
32	We follow policy to allow patients to revoke authorization to disclose or use PHI at any time.		L		
33	We follow policy to allow individuals to file complaints about possible violations of privacy.		L		
34	We have included HIPAA provisions in contracts with business partners. We utilize the 's Business Associate Agreement. All Business Associate Agreements are on file in both the unit and Legal Affairs.		M		
35	We have notified employees of the 's policies and procedures regarding disciplinary processes and potential sanctions for individuals violating HIPAA-related polices.		N		
36	We have informed all employees and supervisors of the prohibition against retaliatory action and intimidation.		O		
37	We retain relevat HIPAA records for at least six years		P		
38	We regularly review policy and procedure documentation.		Q		
39	We have developed and implemented an ongoing internal audit process for reviewing records of system activity (e.g. logins, file accesses, security incidents).		Q		

Totals:	
Yes	0
No	0
Uncertain	0
N/A	0
Not Answered	39
No comments	39

HIPAA Self-Assessment
SECURITY SECTION

Entity: _____

Date: _____

Compiled By: _____

For each item, please provide comments if appropriate, including:

- brief descriptions of implemented practice
- plans and timelines for any "No" answers

Please submit to:

Internal Audit

Item	Specific Requirement	Yes/ No/ Uncertain	Standards	Specs	Comments
1	Is a documented Risk Analysis process used to ensure cost-effective security measures are used to mitigate expected losses?		Security Management Process §164.308(a)(1)	Risk Analysis	
2	Are security measures implemented to reduce risks and vulnerabilities to an appropriate level for the organization?		Security Management Process §164.308(a)(1)	Risk Management	
3	Do documented policies and procedures exist regarding disciplinary actions (stipulations for misuse or misconduct)?		Security Management Process §164.308(a)(1)	Sanction Policy	
4	Have procedures been implemented to regularly review information system activity?		Security Management Process §164.308(a)(1)	Information System Activity Review	
5	Has the security responsibility for the unit been assigned to an individual or group?		Assigned Security Responsibility §164.308(a)(2)	No Implementation Specifications	
6	Is there a formal process in place to allow the reporting of security breaches?		Security Incident Procedures §164.308(a)(6)(i)	Response and Reporting	
7	Are formal procedures followed for timely responding to incidents?		Security Incident Procedures §164.308(a)(6)(i)	Response and Reporting	
8	Are procedures followed for mitigating incidents that may occur?		Security Incident Procedures §164.308(a)(6)(i)	Response and Reporting	
9	At the conclusion of an incident, are procedures followed to document and maintain the outcome of the incident investigation?		Security Incident Procedures §164.308(a)(6)(i)	Response and Reporting	
10	Has a Data Backup Plan been documented, implemented and followed within your organization?		Contingency Plan §164.308(a)(7)(i)	Data Backup Plan	
11	Does the Data Backup Plan contain procedures for testing and revision?		Contingency Plan §164.308(a)(7)(i)	Data Backup Plan	
12	Does the organization follow Data Backup Plan procedures that allow for an exact copy of information to be retrieved?		Contingency Plan §164.308(a)(7)(i)	Data Backup Plan	
13	Does the Data Backup plan call for either full or incremental backups?		Contingency Plan §164.308(a)(7)(i)	Data Backup Plan	
14	Is the backup media safely stored for an appropriate period of time?		Contingency Plan §164.308(a)(7)(i)	Data Backup Plan	
15	Do physical protection mechanisms exist for local and remote copies of backups?		Contingency Plan §164.308(a)(7)(i)	Data Backup Plan	
16	Has a Disaster Recovery Plan been developed and documented?		Contingency Plan §164.308(a)(7)(i)	Disaster Recovery Plan	
17	Has an Emergency Mode Operation Plan been documented and tested to determine continual operations?		Contingency Plan §164.308(a)(7)(i)	Emergency Mode Operation Plan	
18	Do the Emergency Mode Operation Plan and Disaster Recovery Plan address physical access to appropriate personnel?		Contingency Plan §164.308(a)(7)(i)	Emergency Mode Operation Plan	
19	Has an internal or external entity performed a documented assessment on any network or individual system(s) within the network to determine if they meet a pre-specified set of security standards?		Evaluation §164.308(a)(8)	No Implementation Specifications	
20	Does the organization maintain a history of Technical Evaluations for computer system(s) and network(s)?		Evaluation §164.308(a)(8)	No Implementation Specifications	
21	Has an documented inventory of all electronic data exchanges with third parties, vendors or business partners taken place and a Business Associate Agreement been executed, when needed?		Business Associate Contracts and Other Arrangements §164.308(b)(4)	Written Contract or Other Arrangement	
22	If there are any trusted internal or external business connections, or any third party connections or accesses, has a Business Associate Agreement or Memorandum of Understanding been completed?		Business Associate Contracts and Other Arrangements §164.308(b)(4)	Written Contract or Other Arrangement	
23	Does the organization follow procedures for defined acceptable workstation use?		Workstation Use §164.310(b)	No Implementation Specifications	
24	Has the organization implemented physical safeguards to eliminate or minimize unauthorized access/viewing of health information on workstations?		Workstation Security §164.310(c)	No Implementation Specifications	
25	Does the organization implement console locking features?		Workstation Security §164.310(c)	No Implementation Specifications	

26	Does the organization follow procedures for the final disposition of electronic data (including PHI) and the hardware that it resides on?		**Device and Media Controls §164.310(d)(1)**	**Disposal**	
27	Have procedures been developed for removing electronic Protected Health Information from media before it is scheduled for re-use?		**Device and Media Controls §164.310(d)(1)**	**Media Re-use**	
28	Are unique user id(s) in place/use (network and application)?		**Access Control §164.312(a)(1)**	**Unique User Identification**	
29	Are there NO shared ID's or non-unique ID's in use?		**Access Control §164.312(a)(1)**	**Unique User Identification**	
30	Do all end users of network resources have a unique user ID?		**Access Control §164.312(a)(1)**	**Unique User Identification**	
31	Is an emergency access procedure documented and followed?		**Access Control §164.312(a)(1)**	**Emergency Access**	
32	Are networked systems configured to allow event reporting?		**Audit Controls §164.312(b)**	**No Implementation Specifications**	
33	Are auditing capabilities enabled for file/record accesses, modifications, or deletions?		**Audit Controls §164.312(b)**	**No Implementation Specifications**	
34	Are software or hardware solutions in place that will provide notification of abnormal conditions that may occur in a networked system?		**Audit Controls §164.312(b)**	**No Implementation Specifications**	
35	Is the signature on the document/data verified as trust-worthy?		**Person or Entity Authentication §164.312(d)**	**No Implementation Specifications**	
36	Are Business Associate contracts in place between the unit and any business associate that might come in contact with the organizations electronic Protected Health Information?		**Business Associate Contracts and Other Arrangements §164.314(a)(1)**	**Business Associate Contracts**	
37	We follow guidelines regarding security of electronic information.		**Policy and Procedures §164.316(a)**	**No Implementation Specifications**	
38	Are documents related to electronic Protected Health Information maintained for the time period prescribed by this rule?		**Documentation §164.316(b)(1)**	**Time Limit**	
39	Is documentation available to those persons responsible for implementing the various procedures required by the HIPAA security rule?		**Documentation §164.316(b)(1)**	**Availability**	